

1. OVERVIEW

An overview of Requirement 10
("Log Everything"), and its
sub-requirements.



REQ. 10: LOG EVERYTHING

REQ. 10: LOG EVERYTHING **OVERVIEW**

Requirement 10 (Log and Monitor All Access to System Components and Cardholder Data) is about logging actions and identifying the root cause of possible attacks.

- The core of this requirement is, basically, logging everything relevant, and ensuring logging mechanisms are healthy;

This requirement focuses mostly on:

- Having logs to save a history of operations, but also to identify anomalies, suspicious activity, major failures;
- Ensuring logs are not tampered with, and ensuring the logging mechanisms are robust;
- Ensuring time synchronization is working properly;

REQ. 10: LOG EVERYTHING

OVERVIEW

The sub-requirements for this requirement include:

- 10.1 Processes and mechanisms for logging and monitoring all access to system components and cardholder data are defined and understood.
- 10.2 Audit logs are implemented to support the detection of anomalies and suspicious activity, and the forensic analysis of events.
- 10.3 Audit logs are protected from destruction and unauthorized modifications.
- 10.4 Audit logs are reviewed to identify anomalies or suspicious activity.
- 10.5 Audit log history is retained and available for analysis.
- 10.6 Time-synchronization mechanisms support consistent time settings across all systems.
- 10.7 Failures of critical security control systems are detected, reported, and responded to promptly.





REQ. 10: LOG EVERYTHING

REQ. 10: LOG EVERYTHING **OVERVIEW**

10.1 Processes and mechanisms for logging and monitoring all access to system components and cardholder data are defined and understood

- The usual sub-requirement. All processes and policies related to logging must have documentation that is accurate and in use, and same for roles/responsibilities;

This is usually tested through:

- Examining the documentation to ensure it's accurate and updated, and that it's being enforced;
- Interviewing personnel to ensure that processes are accurate and being used;

REQ. 10: LOG EVERYTHING

OVERVIEW

10.2 Audit logs are implemented to support the detection of anomalies and suspicious activity, and the forensic analysis of events

- We must log all significant events in the entire CDE;
- Logs must cover all CDE systems and always identify users;
- There are specific categories of actions that must be logged, including admin actions, access to CHD, changes in user privileges, creation/deletion of system objects, unsuccessful actions, and access to the logs themselves;
- Elements like ID, event type, date/time must be logged;

This is usually tested through:

- Examining system configurations, log configurations, log data themselves, interviewing system administrators;
- Verifying the presence of various actions (admin actions, user changes) in logs, as well as their consistency;





REQ. 10: LOG EVERYTHING

REQ. 10: LOG EVERYTHING **OVERVIEW**

10.3 Audit logs are protected from destruction and unauthorized modifications

- This sub-requirement is about log integrity. Basically, users with no permission cannot even view logs, we have mechanisms such as FIM to detect log file changes, and we have backups of logs to restore them if they're tampered with (in a different area outside the CDE networks);

This is usually tested through:

- Examining system configurations, backup configurations, user access privileges, and records of changes to logs;
- Examining the mechanisms that ensure log integrity, vendor configurations, and records of their execution;

REQ. 10: LOG EVERYTHING

OVERVIEW

10.4 Audit logs are reviewed to identify anomalies or suspicious activity

- There are two main categories here;
- One are events to be reviewed daily. Logs of all security events, of all components that store/process CHD, of all critical system components, of all systems with security functions. These must also be automatically detected;
- Logs of all other systems must be reviewed periodically;

This is usually tested through:

- Examining documentation on log review policies and procedures, and interviewing personnel on this;
- Examining the mechanisms for automated log reviews, and their own logs, to verify automatic review execution;





REQ. 10: LOG EVERYTHING

REQ. 10: LOG EVERYTHING **OVERVIEW**

10.5 Audit log history is retained and available for analysis

- This sub-requirement is simple:
- Audit logs must be available for the most recent 12 months;
- The most recent 3 months in specific must be immediately available for analysis;

This is usually tested through:

- Examining of log retention policies and procedures, as well as configurations of audit log mechanisms;
- Interviewing personnel and examining log files to observe the most recent 3 months are, in fact, immediately available;

REQ. 10: LOG EVERYTHING

OVERVIEW

10.6 Time-synchronization mechanisms support consistent time settings across all systems

- This sub-requirement is about ensuring time integrity (even if log content is not tampered with, if timestamps are, intruders could still cause damage);
- We must synchronize logs with some form of time synchronization mechanism, accepting time from an external UTC source and no other source;

This is usually tested through:

- Examining system configurations and time synchronization mechanism data to verify time data is obtained only from trusted sources and can't be modified;
- Observing configurations to confirm timestamp integrity;





REQ.10: LOG EVERYTHING

REQ. 10: LOG EVERYTHING **OVERVIEW**

10.7 (For service providers) Failures of critical security control systems are detected, reported, and responded to promptly

- We must log critical failures of various systems (network security, IDS/IPS, FIM, anti-malware, and others), with appropriate alerts to take immediate action;
- This requirement also includes responding to alerts raised by logs, not just raising these alerts;

This is usually tested through:

- Examining log configurations and records of incidents;
- Examining records to verify actions taken in past failures;
- Examining documentation and interviewing personnel to confirm what IR processes exist (and whether they are followed);

REQ. 10: LOG EVERYTHING

OVERVIEW

How can we summarize, then, this requirement?

- We must have a logging system that covers certain types of actions, such as CHD access, admin actions, changes in users, and others;
- Logs must be protected by restricting access, preventing modifications, backup systems and integrity mechanisms;
- Logs must be reviewed. Certain categories daily (critical systems, systems that deal with CHD, security systems), and others periodically;
- We must retain log history (12 months, 3 months promptly);
- Log timestamps must be enforced (synchronization from trusted sources);
- Critical failures must be logged + alerted to + responded to;



REQ. 10: LOG EVERYTHING

OVERVIEW

EXAMPLES

/01 TIME SYNCHRONIZATION

Using the same time sync for multiple machines is an example of an essential component to the process of interpreting logs of different machines. It's crucial.

/02 PROPER RESPONSES

For service providers, properly responding to a critical security failure may involve many aspects. Restoring security, documenting the duration, added controls...

/03 CORRELATED

As with many other reqs., Req 10 is correlated with others, namely 7 and 8. The more users are identified, and their access is controlled, the better the logs.

REQ. 10: LOG EVERYTHING

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization has logging on its PoS system, recording all user activities, access attempts, transactions, and any changes to system configurations;
- The log storage is centralized, automatically copied every 24 hours, preventing tampering and allowing future review;

E-COMMERCE STORE

- The organization implements detailed logging on all web servers and applications, to track all user interactions, especially those involving CHD entry and retrieval of any type;
- Databases log all queries and access to CHD, capturing information on who accessed which data, from where, and when;

HOTEL CHAIN

- The organization implements a centralized SIEM system to collect, analyze and correlate logs from various sources for real-time monitoring and alerts;
- All systems handling CHD have logging enabled;
- Automated alerts are set up for certain events such as failed logins/unusual access;

PAYMENT PROCESSOR

- The organization maintains detailed logs for all systems involved in payment processing, capturing user IDs, timestamps, and many additional fields for future consultation;
- Monitoring tools analyze logs in real time, enabling quick detection of anomalies and suspicious activities of any sort;

REQ. 10: LOG EVERYTHING

OVERVIEW

KEY TAKEAWAYS

/01 LOGS, LOGS, LOGS

Requirement 10 is all about logging. Logging specific events, specific data, securing the logs, their file integrity, their time integrity and retention.

/03 10.2 LOGS ARE WORKING

The logging mechanism is working, capturing key categories of events such as admin actions, changes to user privileges, access to CHD, and more.

/05 10.4 LOGS ARE REVIEWED

Certain logs, such as all security systems, all systems that store/process CHD, all security systems, etc must be reviewed daily, and others periodically.

/02 10.1 PROCESSES DEFINED

As usual, processes and policies are documented, in an accurate and enforced manner, as well as the roles and responsibilities of personnel involved.

/04 10.3 LOGS ARE PROTECTED

Logs cannot be viewed by users without permission, cannot be changed, are backed up, and we have mechanisms to ensure their integrity.

/06 10.5 LOGS ARE KEPT

We must keep the most recent 12 months of logs, with the 3 most recent months in particular being readily available.

REQ. 10: LOG EVERYTHING

OVERVIEW

KEY TAKEAWAYS

/07 10.6 LOGS ARE TIMELY

Timestamps must have integrity. Log mechanisms must have a time synchronization mechanism that accepts time in UTC from trusted sources, no other.

/08 10.7 LOGS COVER FAILURES

Logs must cover critical failures of various systems related to PCI DSS compliance, must raise alarms, and we must respond to those alarms promptly.